INFORMATION SECURITY MANAGEMENT SYSTEM

Audit Pack

PaketPort Systems GmbH

ISO/IEC 27001:2022 · NIS2 readiness
Report date: 2026-07-07
Generated by `icep` (offline, deterministic)

Executive summary

PaketPort Systems GmbH — Information Security Management System audit pack, generated 2026-07-07.

Scope

The ISMS covers the design, operation, monitoring and continual improvement of PaketPort Systems GmbH's parcel-locker service: the internet-facing Linux edge devices (street-sited lockers) and their fleet-management plane, the cloud-hosted backend (customer application, parcel-routing engine and carrier-API integrations), the supporting corporate IT and identity services, and the people and processes that operate them. It encompasses the end-to-end processing of customers' personal data — names, contact details, delivery addresses and parcel-event records — from locker to backend to carrier, and the related NIS2 and GDPR obligations of an Austrian essential entity.

Boundary: In scope: all production locker edge devices and the OTA/fleet-management plane; the cloud backend, its data stores and APIs; the CI/CD pipeline and source repositories for the customer app and locker firmware; corporate endpoints, identity and email; and the Vienna head office, security operations centre and provisioning depot. Out of scope: the public cloud provider's underlying physical infrastructure (addressed under the shared-responsibility model and the provider's own certifications), carrier partners' internal networks and systems, and the public street locations where lockers stand beyond the locker enclosure itself. Interfaces to these out-of-scope parties are governed by supplier agreements and monitored as third-party risk.

Posture at a glance

- **Certification target:** ISO/IEC 27001:2022
- **Annex A controls:** 25 fully documented of 93 (93 applicable in the SoA)
- **Implementation:** 19/25 documented controls implemented or operating (76.0%)
- **NIS2 readiness:** 82.6% across the Art. 21(2) measures and the Art. 20 duty
- **Risks:** 13 tracked, 0 high/critical unaccepted, 2 formally accepted
- **Improvement actions:** 5 open (0 overdue)
- **Reviews:** 3 controls overdue for review, 1 evidence artifact expired

Management commitment

PaketPort's management, led by the Managing Director, is committed to protecting the confidentiality, integrity and availability of the information entrusted to it by customers, carriers and staff. We establish, operate and continually improve an information security management system aligned to ISO/IEC 27001:2022 and to our duties as a NIS2 essential entity; we set and review measurable security objectives, provide the resources to meet them, comply with applicable legal and contractual requirements including the GDPR, and require every employee and contractor to understand and uphold this commitment. Security responsibilities are assigned, risks are managed to defined criteria, and this policy is reviewed at least annually.

ISMS owner: Alex Rossi (Information Security Officer / ISMS Manager). Management representative: Dana Weber (Managing Director).

Statement of Applicability (ISO/IEC 27001:2022 Annex A)

All 93 Annex A controls, with the applicability decision and its justification. 'Documented' marks controls with a full control record in this register.

Control	Title	Applicable	Reason	Documented	Justification
A.5.1	Policies for information security	Yes	risk	Yes	Top-level security policy sets PaketPort's direction and is required by ISO 27001 clause 5.2.
A.5.2	Information security roles and responsibilities	Yes	best_practice	—	Clear security roles across locker ops, cloud and admin staff prevent accountability gaps.
A.5.3	Segregation of duties	Yes	risk	—	Separating duties like firmware deploy from approval limits fraud and error in a small team.
A.5.4	Management responsibilities	Yes	best_practice	—	Management actively requires staff to apply security controls for lockers and the backend.
A.5.5	Contact with authorities	Yes	legal	—	As a NIS2 operator PaketPort must reach CERT.at, the DSB and police fast during incidents.
A.5.6	Contact with special interest groups	Yes	best_practice	—	Membership in security forums keeps PaketPort current on threats to lockers and logistics IT.
A.5.7	Threat intelligence	Yes	risk	Yes	Internet-facing lockers are constantly scanned, so threat intel guides defence of edge and APIs.
A.5.8	Information security in project management	Yes	best_practice	—	New locker rollouts and app features carry security requirements from design to go-live.
A.5.9	Inventory of information and other associated assets	Yes	risk	Yes	A live inventory of every locker, cloud service and PII store is vital for a dispersed estate.
A.5.10	Acceptable use of information and other associated assets	Yes	best_practice	—	Staff and contractors get clear rules for using PaketPort systems, data and locker tooling.
A.5.11	Return of assets	Yes	best_practice	—	Leavers and field technicians must return laptops, locker keys and maintenance devices.
A.5.12	Classification of information	Yes	risk	—	Classifying customer PII, parcel events and carrier keys drives proportionate protection.
A.5.13	Labelling of information	Yes	best_practice	—	Consistent labels let staff handle classified customer and operational data correctly.
A.5.14	Information transfer	Yes	risk	—	

Control	Title	Applicable	Reason	Documented	Justification
					Parcel events and addresses moving between lockers, cloud and carriers must be encrypted.
A.5.15	Access control	Yes	risk	Yes	Access to the backend, locker management plane and PII is restricted on need-to-know.
A.5.16	Identity management	Yes	risk	—	Every user, technician and service identity across lockers and cloud is uniquely managed.
A.5.17	Authentication information	Yes	risk	—	Passwords, keys and tokens for locker and cloud access are issued and stored securely.
A.5.18	Access rights	Yes	risk	—	Access rights are granted and revoked as staff and carrier partners join, move or leave.
A.5.19	Information security in supplier relationships	Yes	contractual	Yes	Reliance on carriers, cloud and hardware vendors means supplier security must be governed.
A.5.20	Addressing information security within supplier agreements	Yes	contractual	—	Contracts with carriers and the cloud provider set explicit security and PII obligations.
A.5.21	Managing information security in the ICT supply chain	Yes	contractual	Yes	Locker firmware and cloud components arrive via a supply chain assessed for tampering.
A.5.22	Monitoring, review and change management of supplier services	Yes	contractual	—	Carrier API and cloud service changes are reviewed so they don't weaken PaketPort's posture.
A.5.23	Information security for use of cloud services	Yes	contractual	Yes	Routing and the app backend run in the cloud, so cloud security duties are defined and monitored.
A.5.24	Information security incident management planning and preparation	Yes	risk	Yes	Given NIS2 duties and 24/7 lockers, PaketPort keeps a prepared incident-management process.
A.5.25	Assessment and decision on information security events	Yes	risk	Yes	Events from lockers, cloud and monitoring are triaged consistently to identify real incidents.
A.5.26	Response to information security incidents	Yes	risk	—	A defined response limits impact when a locker or backend service is compromised.
A.5.27	Learning from information security incidents	Yes	best_practice	—	Post-incident lessons feed back to harden lockers and the cloud against recurrence.
A.5.28	Collection of evidence	Yes	legal	—	Evidence is collected soundly to support NIS2 reporting and prosecution after tampering.
A.5.29	Information security during disruption	Yes	business	—	Security must hold during outages so parcel handover and customer data stay protected.

Control	Title	Applicable	Reason	Documented	Justification
A.5.30	ICT readiness for business continuity	Yes	business	Yes	Customers rely on 24/7 lockers, so ICT continuity for backend and devices is planned and tested.
A.5.31	Legal, statutory, regulatory and contractual requirements	Yes	legal	—	PaketPort must identify GDPR, NIS2 and Austrian legal obligations binding its data and services.
A.5.32	Intellectual property rights	Yes	legal	—	Licensing of software in lockers and the backend is tracked to avoid IP infringement.
A.5.33	Protection of records	Yes	legal	—	Retention and integrity of contracts, logs and parcel evidence meet legal and evidential needs.
A.5.34	Privacy and protection of personally identifiable information (PII)	Yes	legal	—	Handling customers' names, addresses and parcel events makes GDPR PII protection mandatory.
A.5.35	Independent review of information security	Yes	best_practice	Yes	Periodic independent audits assure the ISMS works ahead of certification.
A.5.36	Compliance with policies, rules and standards for information security	Yes	best_practice	—	Regular checks confirm lockers, cloud and staff follow PaketPort's security rules.
A.5.37	Documented operating procedures	Yes	best_practice	—	Documented runbooks for locker maintenance and cloud ops ensure secure, repeatable handling.
A.6.1	Screening	Yes	risk	—	Technicians reach street lockers and staff handle PII, so lawful screening cuts insider risk.
A.6.2	Terms and conditions of employment	Yes	contractual	—	Employment contracts state each employee's information security responsibilities.
A.6.3	Information security awareness, education and training	Yes	best_practice	Yes	Staff and field technicians are trained to spot phishing and handle customer data safely.
A.6.4	Disciplinary process	Yes	best_practice	—	A formal disciplinary process addresses security policy breaches consistently and fairly.
A.6.5	Responsibilities after termination or change of employment	Yes	risk	—	Confidentiality and access duties persist when staff leave or change roles.
A.6.6	Confidentiality or non-disclosure agreements	Yes	contractual	—	NDAs bind employees, technicians and carrier partners handling customer and ops data.
A.6.7	Remote working	Yes	risk	—	Office and remote staff connect to the cloud backend, so remote-working security is required.
A.6.8	Information security event reporting	Yes	best_practice	Yes	Staff and technicians have an easy channel to report suspected incidents like tampered lockers.

Control	Title	Applicable	Reason	Documented	Justification
A.7.1	Physical security perimeters	Yes	risk	Yes	Offices and any hosting space have defined secure perimeters against intrusion.
A.7.2	Physical entry	Yes	risk	—	Entry to PaketPort offices and technical rooms is limited to authorised people.
A.7.3	Securing offices, rooms and facilities	Yes	best_practice	—	Offices and equipment rooms are physically secured against unauthorised access.
A.7.4	Physical security monitoring	Yes	risk	Yes	Street-sited lockers and premises are monitored via CCTV and alarms to detect tampering.
A.7.5	Protecting against physical and environmental threats	Yes	risk	—	Lockers face weather and vandalism, offices fire and flood, all needing protective measures.
A.7.6	Working in secure areas	Yes	best_practice	—	Procedures govern work in server and comms rooms and other sensitive areas.
A.7.7	Clear desk and clear screen	Yes	best_practice	—	Staff clear desks and lock screens to protect customer data in shared offices.
A.7.8	Equipment siting and protection	Yes	risk	—	Locker hardware and IT equipment are sited to reduce theft, damage and unauthorised access.
A.7.9	Security of assets off-premises	Yes	risk	—	Lockers and technicians' devices operate off-premises in public and must be protected.
A.7.10	Storage media	Yes	risk	—	Storage media in lockers, technician kit and the cloud are managed across their lifecycle.
A.7.11	Supporting utilities	Yes	business	—	Power and connectivity to lockers and hosting are protected to keep services and logs up.
A.7.12	Cabling security	Yes	best_practice	—	Power and network cabling for lockers and offices is protected from interception and damage.
A.7.13	Equipment maintenance	Yes	best_practice	—	Regular maintenance keeps lockers and IT equipment secure and available.
A.7.14	Secure disposal or re-use of equipment	Yes	risk	—	Decommissioned lockers and drives are wiped so residual customer data can't be recovered.
A.8.1	User endpoint devices	Yes	risk	—	Staff laptops and technicians' mobile devices accessing the backend are hardened and managed.
A.8.2	Privileged access rights	Yes	risk	Yes	Admin access to the cloud backend and locker fleet management is restricted and monitored.

Control	Title	Applicable	Reason	Documented	Justification
A.8.3	Information access restriction	Yes	risk	—	Access to applications and personal data is limited by role and need-to-know.
A.8.4	Access to source code	Yes	risk	—	Access to app and locker firmware source code and repositories is restricted and logged.
A.8.5	Secure authentication	Yes	risk	Yes	MFA and strong authentication protect admin, staff and API access to lockers and cloud.
A.8.6	Capacity management	Yes	business	—	Backend and network capacity is planned so parcel routing and lockers stay available at peak.
A.8.7	Protection against malware	Yes	risk	—	Endpoints, servers and Linux edge devices are protected against malware.
A.8.8	Management of technical vulnerabilities	Yes	risk	Yes	Vulnerabilities in the Linux lockers, cloud stack and dependencies are tracked and patched.
A.8.9	Configuration management	Yes	risk	Yes	Secure, consistent baselines are enforced across the Linux locker fleet and cloud services.
A.8.10	Information deletion	Yes	legal	—	Customer PII and parcel data are deleted when no longer needed to meet GDPR minimisation.
A.8.11	Data masking	Yes	best_practice	—	PII is masked in test, support and analytics environments to limit exposure.
A.8.12	Data leakage prevention	Yes	risk	—	DLP controls reduce the risk of customer address and parcel data leaving PaketPort.
A.8.13	Information backup	Yes	business	Yes	Backups of the backend and configuration guard against data loss and enable recovery.
A.8.14	Redundancy of information processing facilities	Yes	business	—	Redundant backend infrastructure keeps lockers and the app available during failures.
A.8.15	Logging	Yes	risk	Yes	Logs from lockers, cloud and access systems are captured to detect and investigate incidents.
A.8.16	Monitoring activities	Yes	risk	Yes	Continuous monitoring of the fleet and backend detects anomalous behaviour and attacks.
A.8.17	Clock synchronization	Yes	best_practice	—	Synchronised clocks across lockers and servers make logs correlatable for investigations.
A.8.18	Use of privileged utility programs	Yes	risk	—	Powerful utility programs on Linux edge devices and servers are restricted and monitored.
A.8.19		Yes	risk	—	

Control	Title	Applicable	Reason	Documented	Justification
	Installation of software on operational systems				Software changes on locker devices and production servers are controlled and approved.
A.8.20	Networks security	Yes	risk	Yes	Networks linking lockers, cloud and carriers are secured against unauthorised access.
A.8.21	Security of network services	Yes	risk	—	Security features and SLAs of network services connecting lockers are defined and enforced.
A.8.22	Segregation of networks	Yes	risk	—	Locker, corporate and cloud management networks are segregated to contain compromise.
A.8.23	Web filtering	Yes	best_practice	—	Web filtering on managed devices reduces exposure to malicious and phishing sites.
A.8.24	Use of cryptography	Yes	risk	Yes	Encryption protects personal data in transit and at rest across lockers, cloud and APIs.
A.8.25	Secure development life cycle	Yes	best_practice	—	The customer app and locker firmware are built under a defined secure development lifecycle.
A.8.26	Application security requirements	Yes	risk	—	Security requirements are specified for the customer app and carrier-facing APIs.
A.8.27	Secure system architecture and engineering principles	Yes	best_practice	—	Systems are designed with defence-in-depth and secure-by-default principles.
A.8.28	Secure coding	Yes	best_practice	Yes	Developers follow secure coding standards to cut vulnerabilities in app and firmware.
A.8.29	Security testing in development and acceptance	Yes	risk	—	Security testing including pen tests gates releases of the app and locker firmware.
A.8.30	Outsourced development	Yes	contractual	—	Any outsourced development is bound by PaketPort's security and quality requirements.
A.8.31	Separation of development, test and production environments	Yes	risk	—	Dev, test and production for backend and firmware are separated to prevent exposure.
A.8.32	Change management	Yes	risk	—	Changes to lockers, backend and networks follow controlled change management.
A.8.33	Test information	Yes	best_practice	—	Test data is chosen and protected so live customer PII is not exposed during testing.
A.8.34	Protection of information systems during audit testing	Yes	best_practice	—	Audit and testing on production systems are planned to avoid disrupting lockers and backend.

Control register (documented controls)

25 controls with owners, implementation status, evidence and review dates. 'Audit status' is the effective status as of the report date (accepted controls whose review date has passed read as expired).

Control	Title	Theme	Owner	Status	Maturity	Audit	Next review	Evidence	Risks
A.5.1	Policies for information security	organizational	Alex Rossi	operating	4/5	accepted	2027-03-01	1	1
A.5.7	Threat intelligence	organizational	Tomas Horak	implemented	3/5	accepted	2027-02-10	1	0
A.5.9	Inventory of information and other associated assets	organizational	Sara Berger	operating	3/5	accepted	2027-02-15	1	1
A.5.15	Access control	organizational	Alex Rossi	operating	3/5	accepted	2027-02-20	1	1
A.5.19	Information security in supplier relationships	organizational	Jan Fischer	implemented	3/5	expired	2026-06-01 (overdue)	1	1
A.5.21	Managing information security in the ICT supply chain	organizational	Jan Fischer	in_progress	2/5	draft	2026-05-20 (overdue)	1	1
A.5.23	Information security for use of cloud services	organizational	Milan Novak	implemented	3/5	accepted	2027-03-05	1	0
A.5.24	Information security incident management planning and preparation	organizational	Alex Rossi	operating	3/5	accepted	2027-03-10	1	1
A.5.25	Assessment and decision on information security events	organizational	Tomas Horak	implemented	3/5	accepted	2027-03-10	1	0
A.5.30	ICT readiness for business continuity	organizational	Milan Novak	in_progress	2/5	reviewed	2026-10-01	1	1
A.5.35	Independent review of information security	organizational	Alex Rossi	implemented	3/5	accepted	2027-02-01	1	0
A.6.3		people		operating	3/5	accepted	2027-03-15	1	1

Control	Title	Theme	Owner	Status	Maturity	Audit	Next review	Evidence	Risks
	Information security awareness, education and training		Petra Klein						
A.6.8	Information security event reporting	people	Alex Rossi	implemented	3/5	accepted	2027-03-12	1	0
A.7.1	Physical security perimeters	physical	Karl Mayer	implemented	3/5	accepted	2027-02-05	1	1
A.7.4	Physical security monitoring	physical	Karl Mayer	implemented	3/5	accepted	2027-02-05	1	1
A.8.2	Privileged access rights	technological	Milan Novak	operating	3/5	accepted	2027-02-20	1	2
A.8.5	Secure authentication	technological	Milan Novak	in_progress	2/5	reviewed	2026-07-20 (due_soon)	1	2
A.8.8	Management of technical vulnerabilities	technological	Tomas Horak	operating	3/5	accepted	2027-03-20	1	2
A.8.9	Configuration management	technological	Sara Berger	implemented	3/5	accepted	2027-03-01	1	1
A.8.13	Information backup	technological	Sara Berger	operating	3/5	accepted	2027-03-01	1	1
A.8.15	Logging	technological	Milan Novak	in_progress	2/5	draft	2026-06-15 (overdue)	1	1
A.8.16	Monitoring activities	technological	Tomas Horak	in_progress	2/5	reviewed	2026-10-15	1	2
A.8.20	Networks security	technological	Milan Novak	implemented	3/5	accepted	2027-03-08	1	1
A.8.24	Use of cryptography	technological	Milan Novak	implemented	3/5	accepted	2027-03-08	1	2
A.8.28	Secure coding	technological	Nina Blaha	in_progress	2/5	draft	2026-07-30 (due_soon)	0	1

Risk register

13 risks with inherent and residual assessments on a 5x5 likelihood x impact scale (Low <=4, Medium 5-9, High 10-14, Critical >=15).

Risk	Title	Owner	Inherent	Treatment	Residual	Acceptance	Target
R-001	Firmware tampering on street-sited lockers	Milan Novak	critical (20)	mitigate	medium (8)	pending	2026-11-30
R-002	Delayed incident detection breaching NIS2 24h/72h deadlines	Alex Rossi	critical (15)	mitigate	medium (8)	pending	2026-09-30
R-003	Data loss / failure to restore backend after outage	Milan Novak	critical (15)	mitigate	medium (6)	pending	2026-09-01
R-004	Unauthorised access via weak authentication or stale accounts	Alex Rossi	critical (16)	mitigate	medium (6)	pending	2026-08-31
R-005	Credential theft via phishing	Petra Klein	critical (16)	mitigate	medium (9)	pending	2026-09-30
R-006	Supplier or cloud provider compromise	Jan Fischer	high (12)	mitigate	medium (6)	pending	2026-08-15
R-007	Exploitation of an unpatched vulnerability	Tomas Horak	critical (16)	mitigate	medium (8)	pending	2026-08-15
R-008	Insufficient logging hampers forensic investigation	Milan Novak	high (12)	mitigate	medium (6)	pending	2026-09-30
R-009	Personal-data breach via application vulnerability	Lena Vogel	critical (15)	mitigate	medium (8)	pending	2026-09-30
R-010	Insider misuse of privileged access	Alex Rossi	high (10)	accept	medium (6)	accepted by Dana Weber	2026-06-30
R-011	DDoS against the locker backend degrades availability	Milan Novak	high (12)	mitigate	medium (6)	pending	2026-10-01
R-012	Non-compliance with NIS2 registration & reporting duties	Dana Weber	medium (8)	mitigate	low (4)	pending	2026-08-01
R-013	Loss of key Linux-platform knowledge (bus factor)	Dana Weber	medium (9)	accept	medium (6)	accepted by Dana Weber	2026-05-30

Evidence index

18 evidence artifacts. Each SHA-256 anchors the artifact to the audit manifest so tampering is detectable.

Evidence	Title	Type	Controls	Collected by	Valid until	Status	SHA-256
EV-001	sshd hardening check (locker fleet)	config_export	A.8.9	Sara Berger	2026-12-01	valid	a909c40ab7c3
EV-002	auditd rule coverage (edge + backend)	config_export	A.8.15, A.8.16	Milan Novak	2026-12-01	valid	929bac696a5b
EV-003	Vulnerability scan summary (container images)	scan_report	A.8.8	Tomas Horak	2026-09-15	valid	18dce233a204
EV-004	Backup restore test record	backup_test	A.8.13, A.5.30	Sara Berger	2026-11-20	valid	c3f973a8111c
EV-005	Quarterly access review (joiners/movers/leavers)	access_review	A.5.15, A.8.2, A.8.5	Alex Rossi	2026-09-30	valid	fb6d8d8d7ede
EV-006	Asset inventory export (CMDB)	config_export	A.5.9	Sara Berger	2027-05-01	valid	2586b57413fd
EV-007	Supplier security register	attestation	A.5.19	Jan Fischer	2026-06-30	expired	792c62e9e7fc
EV-008	SBOM & third-party component assessment	scan_report	A.5.21	Jan Fischer	2026-10-01	valid	4f3fd79c7a7c
EV-009	Cloud tenant hardening baseline	config_export	A.5.23	Milan Novak	2027-03-05	valid	b4d72ad17a34
EV-010	Incident response plan (approved)	policy_doc	A.5.24	Alex Rossi	2027-03-10	valid	73ac26d2f351
EV-011	Incident triage log (sample)	log_export	A.5.25, A.6.8	Tomas Horak	2026-12-01	valid	91b2c1ed225e
EV-012	Awareness training completion report	training_record	A.6.3	Petra Klein	2026-12-05	valid	bfa7f18e289c
EV-013	Locker enclosure physical security review	screenshot	A.7.1	Karl Mayer	2027-02-05	valid	f282ed6c6144
EV-014	Tamper-detection monitoring export	log_export	A.7.4	Karl Mayer	2026-11-10	valid	eae33992721c
EV-015	Management review minutes	attestation	A.5.1	Dana Weber	2027-03-01	valid	f66667d1d241
EV-016	Threat intelligence briefing	attestation	A.5.7	Tomas Horak	2026-07-25	valid	782be7189f0b
EV-017	Internal ISMS audit report	test_record	A.5.35	Alex Rossi	2027-02-01	valid	68207cf0558d
EV-018	Network segmentation & TLS configuration export	config_export	A.8.20, A.8.24	Milan Novak	2027-03-08	valid	73ef2741ce59

NIS2 readiness

Mapping of NIS2 Directive (EU) 2022/2555 Art. 21(2) risk-management measures to the Annex A controls that implement them. Overall readiness: **82.6%**.

Article	Measure	Controls	Readiness
Art. 21(2)(a)	Risk analysis and information system security policies	A.5.1	100.0%
Art. 21(2)(b)	Incident handling	A.5.24, A.5.25, A.6.8, A.8.16	75.0%
Art. 21(2)(c)	Business continuity, backup management and crisis management	A.5.30, A.8.13	50.0%
Art. 21(2)(d)	Supply chain security	A.5.19, A.5.21, A.5.23	66.7%
Art. 21(2)(e)	Security in acquisition, development and maintenance	A.8.8, A.8.9, A.8.28	66.7%
Art. 21(2)(f)	Policies to assess the effectiveness of risk-management measures	A.5.35	100.0%
Art. 21(2)(g)	Basic cyber hygiene practices and security training	A.6.3, A.5.7	100.0%
Art. 21(2)(h)	Cryptography and, where appropriate, encryption	A.8.24	100.0%
Art. 21(2)(i)	Human resources security, access control and asset management	A.5.9, A.5.15, A.8.2	100.0%
Art. 21(2)(j)	Multi-factor authentication and secured communications	A.8.5, A.8.20	50.0%
Art. 20	Governance and management-body accountability	A.5.1	100.0%

Incident reporting (Art. 23)

Phase	Deadline	Trigger / content
early_warning	24 hours	An early warning to CERT.at / the competent authority indicating whether the incident is suspected to be caused by unlawful or malicious acts or could have a cross-border impact.
notification	72 hours	An incident notification providing an initial assessment of the incident, its severity and impact and any indicators of compromise, updating and elaborating on the early warning.
progress_update	on CSIRT request	Status updates and any intermediate findings provided upon request of the CSIRT or the competent authority while the incident is being handled.
final_report	1 month	A final report with a detailed description of the incident, its root cause, its severity and impact, the mitigation measures applied, and any cross-border impact.

Improvement actions (CAPA)

6 actions, 5 open (0 overdue). These are the continual-improvement backlog of the ISMS.

Action	Title	Source	Owner	Status	Due	Overdue
CAPA-001	Roll out MFA to all admin & edge-management access	internal_audit	Milan Novak	in_progress	2026-08-31	—
CAPA-002	Complete centralised Linux audit-logging rollout	risk_assessment	Milan Novak	in_progress	2026-09-30	—
CAPA-003	Remediate two high-severity SSH findings on locker fleet	evidence_review	Sara Berger	open	2026-07-15	—
CAPA-004	Establish SBOM for third-party edge components	risk_assessment	Jan Fischer	open	2026-08-15	—
CAPA-005	Formalise BC plan and run first DR test	management_review	Milan Novak	in_progress	2026-09-01	—
CAPA-006	Complete the security assessment of the new cloud provider	internal_audit	Jan Fischer	verified	2026-02-28	—

Audit status & expiry

Effective audit status of documented controls and evidence validity as of 2026-07-07.

Control audit status

Status	Count
draft	3
reviewed	3
accepted	18
expired	1

Controls overdue for review

Control	Title	Owner	Next review
A.5.21	Managing information security in the ICT supply chain	Jan Fischer	2026-05-20
A.5.19	Information security in supplier relationships	Jan Fischer	2026-06-01
A.8.15	Logging	Milan Novak	2026-06-15

Expired or expiring evidence

Evidence	Title	Valid until	State
EV-007	Supplier security register	2026-06-30	expired
EV-016	Threat intelligence briefing	2026-07-25	expiring